HUTECH
Đại học Công nghệ Tp.HCM

NHÓM 14

MÔN LẬP TRÌNH AN NINH THÔNG TIN

Xây dựng hệ thống phát hiện đăng nhập bất thường dựa trên hành vi người dùng





Giới thiệu thành viên

Hoàng Xuân Đạt	2387700013
Trần Tăng Trường Thịnh	2387701939
Trịnh Thành Đông	2387700372
Hà Tuấn Anh	2387700002

ĐĂNG NHẬP BẤT THƯỜNG DỰA TRÊN HÀNH VI LÀ GÌ?



Là lần đăng nhập có mật khẩu đúng nhưng khác với thói quen thường ngày của chủ tài khoản, dấu hiệu cho thấy có thể người khác đang dùng tài khoản.

Hệ thống hoạt động thế nào:

1. Học thói quen (đường cơ sở): ghi nhận cách mỗi người thường đăng nhập
2. So sánh: đối chiếu lần đăng nhập mới với thói quen đó, tính điểm rủi ro
3. Phản ứng: cho vào · hỏi thêm OTP · chặn và cảnh báo

Vì sao một lần đăng nhập hợp lệ vẫn có thể nguy hiểm?

Mật khẩu đúng ≠ đúng người

Mật khẩu có thể đã bị lộ

Kẻ tấn công dùng đúng mật khẩu bị lộ (lừa đảo, rò rỉ dữ liệu, dùng lại mật khẩu) để vượt qua lớp xác thực cơ bản.

Cần nhận ra sự "lệch thói quen"

Bài toán là phát hiện khi một lần đăng nhập khác với thói quen quen thuộc của chính người dùng đó.



Hệ thống cần quan sát những tín hiệu nào?

Ngữ cảnh

- Thời gian
- Địa chỉ IP
- Vị trí tương đối

Thiết bị

- Hệ điều hành
- Trình duyệt
- Dấu vân tay trình duyệt

Hành vi

- Nhịp gõ phím
- Nhịp độ thao tác
- Số phiên

Lịch sử

- Số lần nhập sai
- Hành vi sau đăng nhập
- Lịch sử thay đổi

Gom lại thành một “dấu vân tay hành vi” riêng của từng người dùng

Tín hiệu đổi thành điểm rủi ro có thể giải thích



Mỗi cảnh báo phải nêu được lý do

- Điểm = tổng có trọng số của thiết bị, vị trí, thời gian, tốc độ, lịch sử
- Quản trị viên kiểm tra được
- Người dùng hiểu vì sao bị hỏi thêm
- Dễ chỉnh trọng số khi báo nhầm

Luồng phản ứng thích ứng theo mức rủi ro

Rủi ro thấp

Điểm 0–29

Cho phép đăng nhập và ghi nhận

Máy quen, giờ quen, nhịp gõ khớp: người dùng không bị làm phiền

Rủi ro trung bình

Điểm 30–59

Yêu cầu MFA hoặc xác minh bổ sung (OTP)

Máy lạ, giờ lạ: đúng chủ tài khoản thì vẫn vào được

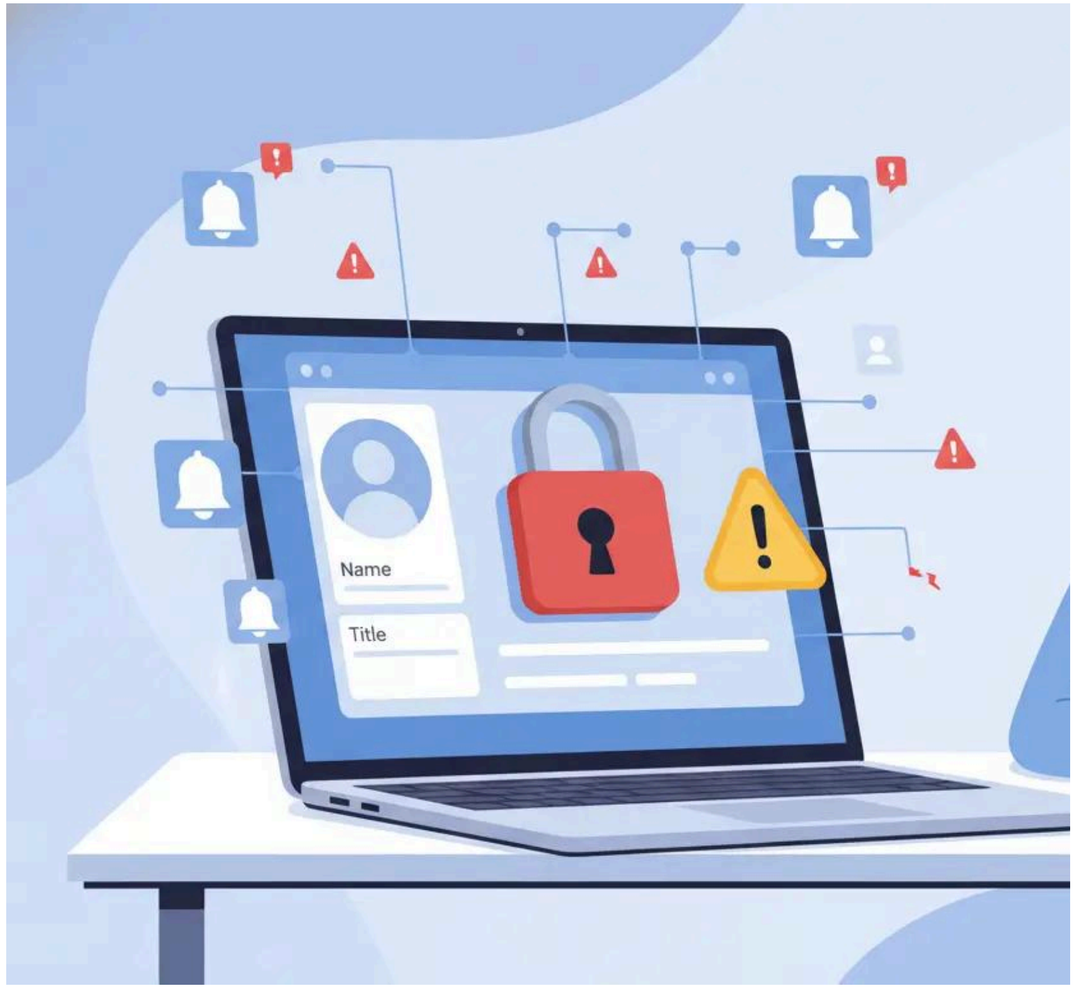
Rủi ro cao

Điểm ≥ 60

Tạm khóa phiên, cảnh báo, chuyển người phụ trách

Nhiều dấu hiệu cùng lúc, hoặc di chuyển bất khả thi

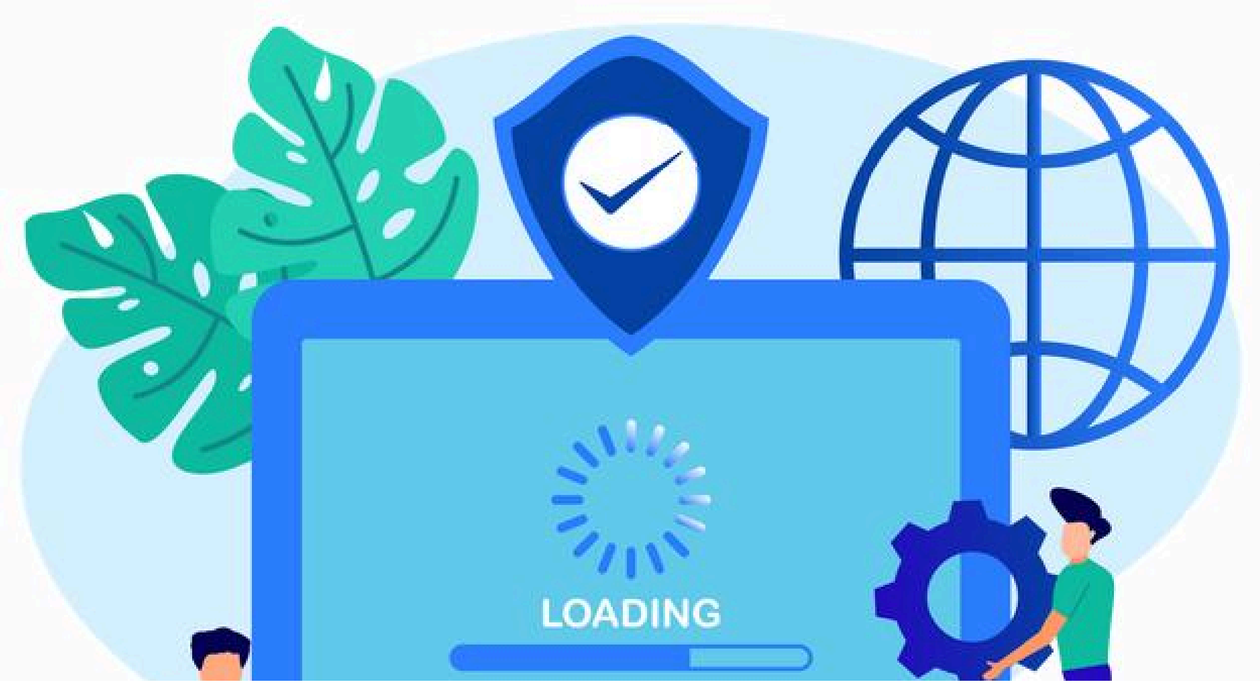
MFA thích ứng: chỉ hỏi thêm xác minh khi rủi ro tăng, nên an toàn hơn mà không làm phiền người dùng thật. Google, Microsoft và ngân hàng đều áp dụng.



HẬU QUẢ

1. Đối với người dùng
   - Mất quyền kiểm soát tài khoản: bị đổi mật khẩu, email, số điện thoại khôi phục.
   - Bị đánh cắp thông tin cá nhân, tin nhắn, ảnh và dữ liệu riêng tư.
   - Mất tiền, bị mạo danh để lừa đảo người thân và bạn bè.
2. Đối với doanh nghiệp
   - Lộ dữ liệu khách hàng và dữ liệu nội bộ khi tài khoản nhân viên bị chiếm.
   - Tốn chi phí điều tra, khôi phục hệ thống và xử lý khiếu nại.
   - Mất uy tín, có thể bị phạt do vi phạm quy định bảo vệ dữ liệu cá nhân.
3. Đối với xã hội
   - Giảm niềm tin của người dùng vào dịch vụ trực tuyến.
   - Tạo điều kiện cho lừa đảo, mạo danh và tội phạm công nghệ cao lan rộng.
   - Một mật khẩu bị lộ có thể bị dùng để tấn công hàng loạt tài khoản ở các dịch vụ khác.

BIỆN PHÁP PHÒNG CHỐNG



1. Đối với người dùng

- Dùng mật khẩu mạnh, không dùng chung cho nhiều tài khoản.
- Bật xác thực 2 lớp (2FA), không chia sẻ mã OTP cho bất kỳ ai.
- Kiểm tra kỹ đường link trước khi đăng nhập, chú ý cảnh báo "đăng nhập lạ".

2. Đối với doanh nghiệp

- Áp dụng xác thực đa yếu tố, băm mật khẩu an toàn (bcrypt).
- Giới hạn số lần đăng nhập sai, tạm khóa khi bị dò mật khẩu.
- Giám sát nhật ký đăng nhập, cảnh báo sớm hành vi đáng ngờ.

3. Giải pháp hệ thống phát hiện theo hành vi

- Học thói quen đăng nhập của từng người: giờ, vị trí, thiết bị, nhịp gõ phím.
- Tính điểm rủi ro cho mỗi lần đăng nhập bằng luật và học máy.
- Phản ứng thích ứng: cho vào, hỏi OTP hoặc chặn theo mức rủi ro.



KẾT LUẬN

- Đăng nhập bất thường là một trong những rủi ro phổ biến nhất hiện nay. Khi mật khẩu bị lộ, kẻ gian có thể chiếm đoạt tài khoản, đánh cắp thông tin cá nhân, gây thiệt hại tài chính và ảnh hưởng đến uy tín của doanh nghiệp.
- Hệ thống phát hiện đăng nhập bất thường dựa trên hành vi giúp nhận ra kẻ gian kể cả khi có đúng mật khẩu, bằng cách học thói quen của từng người dùng và kết hợp luật, học máy, nhịp gõ phím. Hệ thống chỉ hỏi thêm OTP hoặc chặn khi thật sự nghi ngờ, nên vừa an toàn vừa không gây phiền cho người dùng thật.

Thank You